

Análisis Forense Informático

Unidad 3. Análisis de medios de almacenamiento

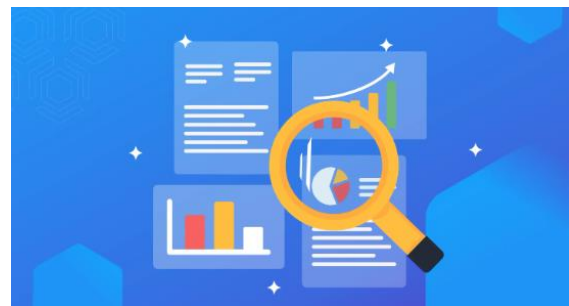


Índice

1	Análisis de los datos.....	2
1.1	Metodología propuesta para el análisis de disco.....	2
1.2	Metodología propuesta para los informes.....	2
2	Tipos y estructuras en medios de almacenamiento.....	3
2.1	Disco duro (HDD).....	3
2.2	Disco SSD.....	4
2.3	Disco Ópticos.....	4
2.4	Particionado de un disco.....	4
2.5	Arranque del S.O.....	6
2.6	Sistemas de ficheros.....	6
3	Análisis de los medios de almacenamiento.....	7
3.1	Progresión en el análisis de los medios.....	8
4	Análisis de metadatos.....	9
5	Análisis de palabras clave.....	9
5.1	Lista de palabras clave.....	10
5.2	Expresiones regulares.....	10
6	Recuperar datos borrados (buscar en el espacio no asignado).....	14
7	Proceso de búsqueda con Carving (cortar, esculpir).....	15
7.1	Herramientas de Carving.....	17
8	Análisis de metadatos internos.....	17
9	Análisis de hashes.....	18
10	Buscar información oculta en el disco.....	19
11	Análisis de los artefactos del Sistema Operativo.....	19
11.1	El registro de Windows.....	20
12	Otras fuentes de evidencias.....	20
12.1	Análisis de red.....	20
12.2	Análisis de memoria.....	21
12.3	Análisis de archivos de intercambio (swap).....	21
12.4	Análisis de esteganografía.....	21
12.5	Análisis de firmas de malware.....	21
13	Otras formas de esconder información en los discos.....	22
14	Referencias.....	23

1 Análisis de los datos.

Una vez que se han adquirido los datos en el análisis forense digital, el siguiente paso es analizar los datos obtenidos. Existen diversos métodos y herramientas que se pueden utilizar.

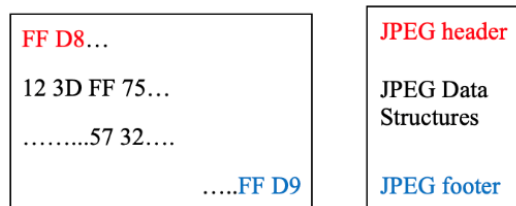


1.1 Metodología propuesta para el análisis de disco

Es fundamental seguir un proceso riguroso y documentado para garantizar la integridad de los datos y la evidencia.

1. Analizar los medios: Empezar analizando las tablas de particiones del disco sospechoso para buscar volúmenes con sistemas de archivos.
2. Analizar los metadatos de los archivos, dentro de los sistemas de archivos, para generar una línea de tiempo (timeline).
3. Buscar archivos usando una lista de palabras clave relacionadas con el caso. Usar expresiones regulares (Regex).
4. Recuperar los posibles archivos borrados.
5. Hacer Carving: Analizar todos los bloques de disco o de ficheros buscando las firmas de ficheros (magic number), ignorando el sistema de archivos y el nombre o extensión del archivo.
6. Analizar metadatos internos de los **archivos**.
7. Hacer un análisis de Hash, para comprobar ficheros sospechosos o no <https://flylib.com/books/en/3.210.1.47/1/>
8. Buscar información oculta en el disco.
9. Analizar los artefactos del sistema operativo.

JPEG FILE STRUCTURE



1.2 Metodología propuesta para los informes

El informe se debe ir completando a medida que realizamos la investigación. Hay que registrar:

- La tarea asignada y una explicación de los objetivos de la investigación e hipótesis a demostrar.
- Los pasos seguidos, el equipamiento y las metodologías utilizadas.
- Los hechos o datos:
 - Que apoyen las hipótesis.
 - Que rechacen las hipótesis

- Descubrimientos y conclusiones escritas:
 - Que se podrían utilizar en el juzgado.
 - Interesantes por la organización

Hay que empezar el informe desde el principio, explicándolo todo:

- Incluir detalles de análisis junto con los datos (archivos recuperados, valores del registro, palabras clave encontradas, etc.)
- Las declaraciones y conclusiones deben ser expresadas de manera exacta. Frases útiles son:
 - "Basándome en mi experiencia profesional..."
 - "La evidencia indica..."
 - "Basado en mi conocimiento..."
- Nunca se debe expresar una opinión en las declaraciones o conclusiones

2 Tipos y estructuras en medios de almacenamiento.

Los medios de almacenamiento son dispositivos que son capaces de almacenar y servir información digital mediante diversas tecnologías: **electrónica** (memorias flash, discos SSD), **magnética** (discos duros HDD tradicionales) y **óptica** (CDs / DVDs).

Cada tecnología puede significar el uso de unas metodologías u otras para la adquisición de los datos, así como las técnicas de recuperación, ocultación e integridad de los datos que contiene.

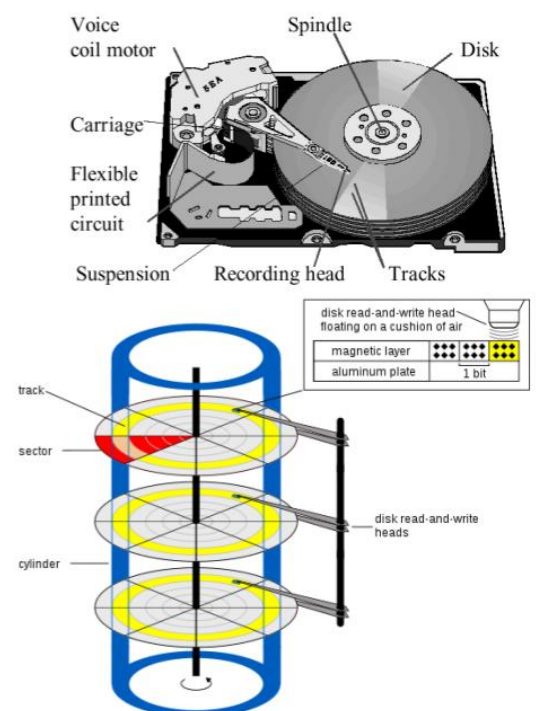
También es crítico disponer de los recursos necesarios para las adquisiciones (dispositivos, cables, etc).

2.1 Disco duro (HDD)

La información se almacena mediante la magnetización de unas partículas que se distribuyen en pistas concéntricas a lo largo de la superficie de las caras de los discos.

En cada operación de lectura/escritura, el dispositivo lee o escribe una determinada cantidad de información denominada tamaño de bloque. Viene determinado por la estructura del disco y suele ser de 512 bytes.

Para su manipulación se utilizan bloqueadores de escritura (write-blockers) para evitar alterar su contenido, ya vistos anteriormente.



2.2 Disco SSD

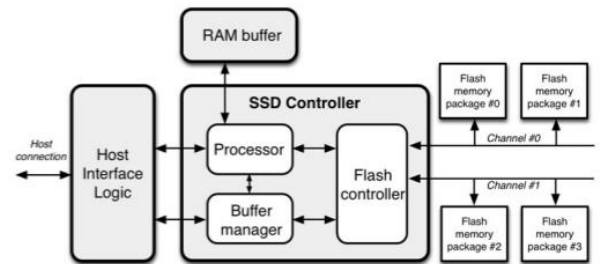
La persistencia de la información se consigue mediante el uso de celdas electrónicas NAND.

Simulan el funcionamiento de un disco duro tradicional magnético, de forma que el concepto de bloque sigue existiendo aunque de forma abstracta.

Hay que tener cuidado al manipularlos puesto que el propio dispositivo lleva a cabo operaciones que pueden alterar evidencias con tan solo encenderlo.



Architecture of a solid-state drive



2.3 Disco Ópticos

La información se almacena físicamente en microsurcos que, al ser leídos por un láser, reflejan o no la luz de este codificando la información.

Desde el punto de vista forense no tienen tanta relevancia como los anteriores ya que no registran información del sistema operativo, sino que solo pueden almacenar información adicional posiblemente útil.



2.4 Particionado de un disco

Los discos pueden dividirse de forma lógica en particiones, las cuales disponen de su propio sistema de ficheros con el formato deseado.

Esto nos permite por ejemplo:

- Usar distintos sistemas de ficheros
- Separación de información (p.e. datos de programas)
- Limitar almacenamiento de un usuario
- ...

Para el establecimiento de las particiones se utilizan esquemas de partición. Los más utilizados y conocidos son MBR (Master Boot Record) y GPT (GUID Partition Table).

Master Boot Record

Es el sistema tradicional de siempre, de hecho aún sigue estando muy extendido.

En los primeros 512 bytes del disco se almacena el esquema de particiones en una tabla de particiones.

```
# dd if=/dev/sda of=mbr.bak bs=512 count=1
1+0 records in
1+0 records out
512 bytes copied, 0.000628953 s, 814 kB/s
```

Copia de la MBR desde Linux usando dd

Como es de suponer, 512 bytes no dan para mucho. Por este motivo solo se pueden definir 4 particiones primarias.

Offset	Descripción
0x00	Estado (0x80 = bootable, 0x00 = non-bootable)
0x01	Cilindro, Cabezal, Sector (CHS) del primer sector en la partición
0x04	Tipo de partición
0x05	Cilindro, Cabezal, Sector (CHS) del último sector de la partición
0x08	(4 bytes) <i>Logical block address</i> del primer sector de la partición
0x0C	(4 bytes) Longitud de la partición, en sectores

Entrada de la tabla de particiones
(una por cada partición primaria)

GUID Partition Table (GPT)

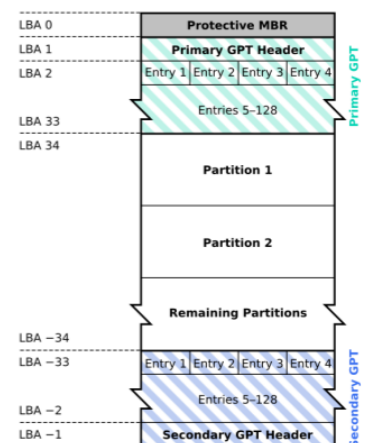
Es el sistema moderno para determinar las particiones de una unidad de almacenamiento.

Incrementa el número de particiones disponibles (128) y el tamaño máximo de estas (18 exabytes).

Se utilizan los primeros 32 bloques de 512 bytes (16 KB) y los 32 últimos como redundancia. La entrada por cada partición ocupa 128 bytes.

Tanto al disco como a las particiones se les asigna un Globally Unique Identifier (GUID) que los diferencia del resto de objetos del sistema (usuarios, librerías, sesiones, etc).

GUID Partition Table Scheme



Offset	Longitud	Descripción
0 (0x00)	16 bytes	Tipo de partición GUID
16 (0x10)	16 bytes	GUID único de partición
32 (0x20)	8 bytes	Inicio LBA
40 (0x28)	8 bytes	Fin LBA
48 (0x30)	8 bytes	Indicadores
56 (0x38)	72 bytes	Nombre de partición

2.5 Arranque del S.O.

Es importante conocer y comprender el proceso de arranque de un sistema operativo de forma que podamos detectar qué sistema de archivos ha cargado un dispositivo o qué modificaciones se han podido producir como medidas antiforenses.

También es útil en caso de que el dispositivo esté dañado y no pueda arrancar.

Los elementos principales encargados de esto son:

- **BIOS (Basic Input Output System):** asociado con MBR. Se utiliza el firmware del dispositivo para buscar particiones arrancables en MBR y cargarlas.
- **UEFI (Unified Extensible Firmware Interface):** sistema más moderno que permite la carga de aplicaciones UEFI en los sistemas de ficheros de las particiones (tipo FAT), puede conectarse a Internet y permite los Secure Boot.

2.6 Sistemas de ficheros.

Independientemente de la tecnología en la que esté basado un dispositivo de almacenamiento, se puede establecer una estructura de organización lógica en este llamada sistema de ficheros.

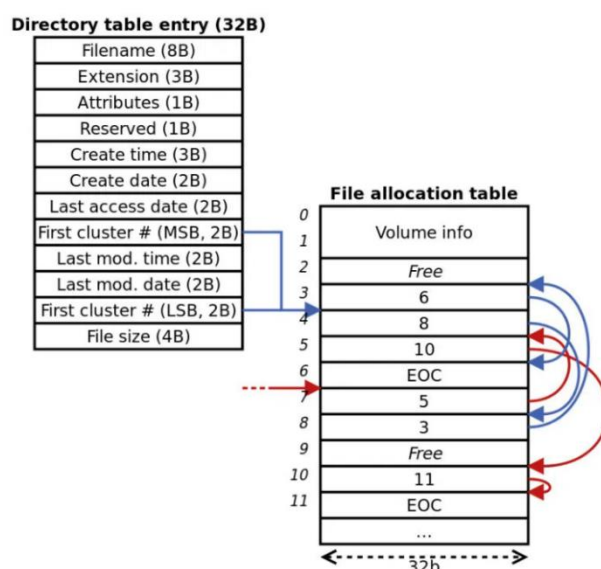
En resumen, los bloques o sectores del dispositivo se asignan en agrupaciones lógicas, las cuales a su vez se asignan a ficheros.

Algunos sistemas de ficheros han evolucionado con el tiempo y han implementado:

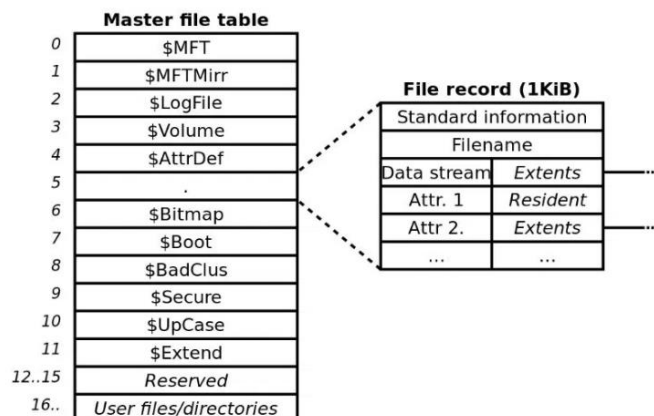
- **Journaling:** registro de las operaciones realizadas en el dispositivo.
- **ACL de ficheros:** control de qué operaciones puede realizar un determinado usuario.
- **Cuotas:** para controlar la cantidad de almacenamiento utilizada por un determinado usuario.

Centrándonos en Windows, los sistemas de ficheros más utilizados en la actualidad son:

- **FAT:** sistema antiguo y simple ampliamente soportado por la mayoría de los dispositivos.



- **NTFS**: sustituto de FAT más evolucionado que soporta tamaños de archivos más grandes, uso de cifrados, permisos de archivos, etc.



Nos centraremos en este último, ya que en la actualidad es el sistema de ficheros más utilizado.

NTFS

Es el sistema principal utilizado en los entornos Windows. La principal fuente de información forense del sistema de ficheros NTFS es la **Master File Table (MFT)**. Esta tabla contiene o referencia de manera indirecta toda la información posible de un archivo: timestamps, tamaño en bytes, atributos, directorio padre y su contenido.

En resumen, cuando el investigador forense dispone de una copia de la MFT de un sistema Windows, tiene un catálogo de todos los archivos que existen en ese volumen, **además de aquellos que hayan podido ser eliminados recientemente**.

Cada volumen NTFS contiene su propia MFT, la cual se almacena en el directorio raíz del volumen como un archivo denominado **\$MFT**.

A la hora de manejar un sistema con múltiples unidades o particiones hay que asegurarse de adquirir la MFT de cada volumen.

3 Análisis de los medios de almacenamiento.

Analizaremos dispositivos de almacenamiento físicos cómo:

- discos duros
- discos SSD
- pendrives
- discos ópticos
- memorias flash
- tarjetas sd, microsd, ...

En estos dispositivos podemos centrarnos en analizar:

1. **El espacio asignado con contenido (ficheros existentes) o "Allocated space"** con espacio asignado. El sistema de archivos reconoce este espacio como utilizado. Los ficheros están disponibles de forma normal.
2. **Espacio no asignado "Unallocated space"**. No está ocupado por archivos, aunque puede contener datos de algún archivo previamente borrado. Estos clústeres o bloques están disponibles para ficheros y corren el riesgo de ser sobrescritos en cualquier momento.

3. **Espacio desaprovechado "Slack space":** Es el espacio que sobra en un clúster o bloque porque el fichero que se guarda no lo llena completamente.
4. **Sectores/bloques/clústeres marcados como erróneos o "Bad blocks".** En principio son bloques defectuosos que el sistema ha descartado por no usarlos, pero pueden haber sido marcados así para esconder información.
5. **Zonas del disco escondidas** o usadas por el sistema.
 - Son zonas reservadas que en principio no son accesibles para los sistemas de archivos.
 - Los usuarios no pueden ver que existen.

3.1 Progresión en el análisis de los medios

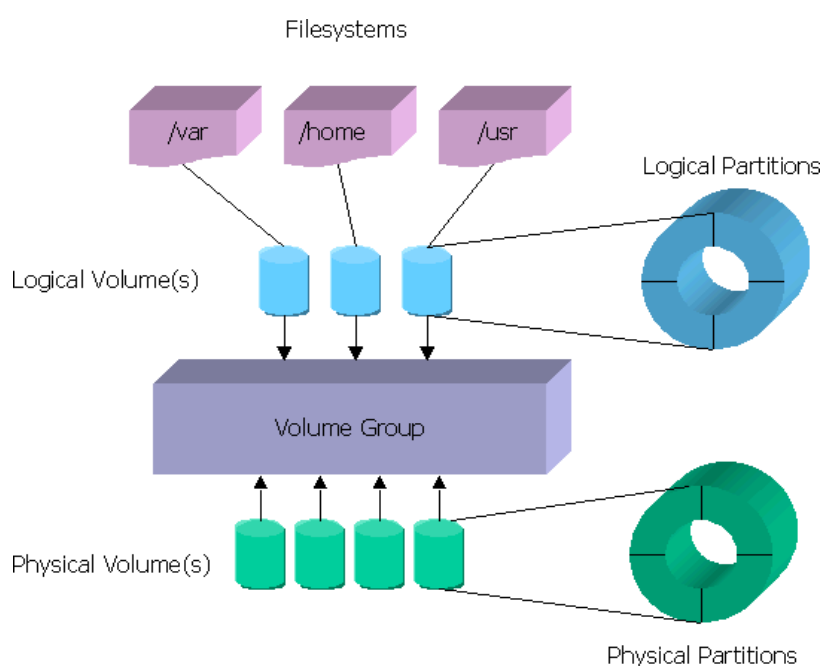
Una vez hecha la **extracción** de las evidencias, deben **examinarse** para organizarlas en:

- tipo (documentos, fotos o imágenes, comprimidos, cifrados, etc.)
- por extensión
- por contenido, etc.

Y a continuación las **analizaremos**.

La finalidad del análisis de medios es encontrar **artefactos**, entendidos como objetos del sistema que aportan información, y que sean relevantes para **probar o rebatir las hipótesis** (si las hay) que hayamos construido.

La **progresión en el análisis de medios** se desglosa en niveles:



Sistema LVM (Logical Volume Manager) de Linux

1. **Disco físico:** Es el almacenamiento físico en dispositivos como discos duros, SSD o dispositivos flash.
2. **Volumen lógico:** Es un contenedor que comprende 1 o más discos. Se puede confundir con el término partición:
 - o la **partición está confinada a un solo disco físico**
 - o **el volumen puede abarcar más de un disco físico o diferentes partes de diferentes discos físicos.**
3. **Sistema de archivos:** Se utiliza para **gestionar ficheros dentro de un volumen lógico**. Controla por ejemplo la creación de ficheros y el espacio libre y ocupado.
4. **Unidad de datos:** La unidad mínima de información en el sistema de ficheros. En Unix se llaman **bloques** y en Windows **clústeres o unidades de asignación**.
5. **Metadatos:** Los datos sobre los datos, o sea, **datos que describen cómo son los datos almacenados**. Incluye información como marcas de tiempo de modificación, acceso, y creación, así como de otras informaciones para gestionar los ficheros.

Algunos ficheros contienen de forma interna (dentro del espacio asignado), algunos **metadatos**. Por ejemplo las **datos EXIF** de ficheros jpg o los **metadatos de ficheros de Office o Microsoft 365**.

4 Análisis de metadatos

Implica examinar la información que se encuentra en los metadatos de los archivos:

- fecha y hora de creación
- la última fecha de acceso
- el tamaño del archivo, entre otros.
- **Herramientas:** Autopsy, MFT Explorer (<https://ericzimmerman.github.io>), etc.

```
File Type Extension : jpg
MIME Type           : image/jpeg
Exif Byte Order      : Big-endian (Motorola, MM)
Make                : Google
Camera Model Name    : Pixel 3 XL
Orientation          : Horizontal (normal)
X Resolution         : 72
Y Resolution         : 72
Resolution Unit      : inches
Software             : HDR+ 1.0.296349522zdh
Modify Date          : 2020:03:13 16:13:27
Y Cb Cr Positioning  : Centered
Exposure Time        : 1/60
F Number             : 1.8
Exposure Program     : Program AE
ISO                  : 68
Exif Version         : 0231
Date/Time Original   : 2020:03:13 16:13:27
Create Date          : 2020:03:13 16:13:27
```

Esta información puede ayudar a establecer una **línea de tiempo de los acontecimientos y acciones realizadas** en un sistema o dispositivo.

5 Análisis de palabras clave

Es el **método básico que podemos utilizar para investigar** a una imagen de disco y/o memoria. Implica **buscar palabras o frases específicas** que puedan estar relacionadas con el incidente o el delito en cuestión.

Para ello podemos utilizar herramientas de búsqueda, como grep o strings. Además se pueden utilizar expresiones regulares.

Para usar este método podemos utilizar:

- **Listas de palabras clave.**
- **Expresiones regulares.**

En los archivos con texto, nos podemos encontrar diferentes sistemas de codificación, y debemos tenerlo en cuenta. Por ejemplo:

- **ASCII(American Standard Code for Information Exchange):** limitado a 256 códigos y en principio para lenguaje inglés (1 byte). <https://elcodigoascii.com.ar/>
- **Unicode:** desarrollado para superar las limitaciones de ASCII. Cada carácter ocupa 8, 16 o 32 bits, según la codificación UTF-8, UTF-16 o UTF-32. <https://es.wikipedia.org/wiki/Unicode>

5.1 Lista de palabras clave.

Pueden ser de dos tipos:

- **Genéricas:** Útiles en cualquier caso. Ej: listas de conceptos relacionados con un tipo de investigación:
 - **Relacionadas con** actividades fraudulentas: "comisión", "pago", "contrato", "dinero B", "dinero negro", "cuenta"...
 - **Relacionadas con** imágenes ilícitas: "porn", "babies", etc
 - **Conocidas en la jerga:** "avion", etc
- **Específicas:** Hechas a medida para el caso actual.
 - **nombres** de trabajadores de la empresa
 - usuarios participantes **en el suceso investigado**
 - lugares conocidos
 - el lenguaje específico que usan los participantes ("jerga" informática, jurídica, contable, etc.), etc.

5.2 Expresiones regulares.

Cuando buscamos cadenas podemos **crear patrones de búsqueda con las expresiones regulares (RegEx)**. De esta manera obtenemos flexibilidad en las búsquedas (por ejemplo, para ignorar mayúsculas y minúsculas, palabras que empiezan por una raíz determinada, etc.).

Una **expresión regular** es una cadena de caracteres para generar un patrón (pattern). Según la utilidad utilizaremos unos símbolos u otros, aunque hay cosas comunes. Hay que mirar la documentación de la herramienta.

Estas expresiones son utilizadas, por ejemplo, para buscar:

- correos electrónicos
- números de cuenta
- teléfonos
- URL's
- número de tarjeta de crédito
- número de la seguridad social, etc.

Ejemplos con grep

Buscar una dirección IP

```
$ cat exemple.txt
hola
que tal
192.168.0
dasd
192.168.0.255
sdfjjlkdsf
sdfñlfsdjk
10.8.1.1

$ grep -E "[0-9]{1,3}\.[0-9]{1,3}\.[0-9]{1,3}\.[0-9]{1,3}" exemple.txt
192.168.0.255
10.8.1.1

$ grep -E "([0-9]{1,3}\.){3}[0-9]{1,3}" exemple.txt
192.168.0.255
10.8.1.1

$ grep -E "([[:digit:]]{1,3}\.){3}[[:digit:]]{1,3}" exemple.txt
192.168.0.255
10.8.1.1
```

Buscar palabras con unos caracteres o no

```
$ cat ex2.txt pato
p3to
p4to
plto
p0to
peto
pito
poto
puto

$ gripe -E "p[ia]to" ex2.txt
pato
Pito

$ grep -E "p[^ia]to" ex2.txt
p3to
p4to
plto
p0to
peto
poto
```

Validar un email

```
[a-zA-Z0-9_+.-]+@[a-zA-Z0-9.-]+\.[a-zA-Z]{2,}
```

Validar un teléfono

```
^\+? ([0-9]{1,3})?\s?(? [0-9]{3}\)? [-\s.]? [0-9]{3}[-\s.]? [0-9]{4,6}$
```

Símbolos más utilizados por RegExp

Símbolo	Significado
.	Representa cualquier carácter, una vez.
*	Indica que el anterior símbolo puede estar de 0 a infinitas veces. Ej: ca*t podría ser cat, caat, caaat, etc.
.*	Representa cualquier carácter, de 0 a infinitas veces.
?	Indica que el anterior símbolo puede NO estar. Ej: .e01? podría ser ".e01" o ".e0"
+	Indica que el anterior símbolo puede estar de mínimo 1 a infinitas veces.
\	Indica que el siguiente carácter se toma de forma literal. Ej: \. quiere decir que no se interprete la acción asociada al '.' si no un '.' literal. Ej: "fin\". es la expresión "fin." y poner \\hola sería la expresión "\\hola" indicando que queremos el símbolo "\" literal.
^	Indica principio de línea. Ej: ^123 muestra las líneas que empiezan por 123.
\$	Indica final de línea. Ej: 123\$ muestra las líneas que terminan por 123.
{n}	Indica que el anterior símbolo puede estar a veces. Ej: a{3} es "aaa"
{n.m}	Indica que el anterior símbolo puede estar de n a m veces. Ej: a{1,3} es "a", "aa", "aaa".
(...)	Agrupar símbolos y expresiones. Ej: (ab){2} sería abab. ((ab){2}) ((ab){2}) sería "abab abab" (con espacio en medio).
[...]	Indica que puede ser uno de los símbolos entre los "claudátores". Ej: p[aeiou]to puede ser "pato", "peto", "pito", "poto", "puto".
[^...]	Indica que no puede ser uno de los símbolos entre los "claudátores". Ej: p[^aei]to puede ser "poto", "puto", "p3to", "pgto", etc. pero no puede ser "pato", "peto", "pito".
[...-...]	Indica que el símbolo está dentro del rango marcado por los caracteres entre el guión. Ej: [a-z] es sólo un símbolo de 'a' a 'z'. [a-zA-Z] es sólo un símbolo de 'a' a 'z' o de 'A' a 'Z'.

ATENCIÓN: El rango depende de la codificación de los símbolos, de manera que [0-9] son todos los símbolos del código ASCII del 48 a 57 y no se puede escribir como [1-0] por que el último símbolo tiene un código menor que el primero. Hay que mirar la tabla ASCII y/o Unicode antes <https://elcodigoascii.com.ar/> y <https://www.ssec.wisc.edu/~tomw/java/unicode.html>

Aprender y verificar expresiones regulares

Herramientas para poder profundizar en las expresiones regulares:

- RegExp Wikipedia - https://en.wikipedia.org/wiki/Regular_expression
- 2025 - Cyberchef (escoger regular expresiones). <https://gchq.github.io/CyberChef>
- 2024 - Texto y graph RegEx (it-tools.tech recopilación de herramientas) - <https://it-tools.tech/regex-tester>
- 2024 - Visualizador gráfico de expresiones regulares de Javascript - <https://regexper.com/>
- Expresiones regulares (grep y otros). Para aprender y hacer pruebas de forma visual
 - <https://regexr.com/>
 - <https://regex101.com/>
- (2023) RegexGolf - retos regex interactivo - <https://alf.nu/RegexGolf?world=regex&level=r00>
- (2023) Regex Crosswords - <https://regexcrossword.com/>
- Juego para aprender (retos en forma de historia) - <https://www.therobinlord.com/projects/slash-escape>
- Regex Cheat Sheet, con vídeo (2020)- <https://fireship.io/lessons/regex-cheat-sheet-js/>

6 Recuperar datos borrados (buscar en el espacio no asignado)

Cuando un fichero es borrado en diferentes sistemas de ficheros, normalmente lo que pasa es que:

1. Sólo se borra la entrada de la tabla de directorios o archivos su nombre o la inicial del nombre en **FAT** (ya que sólo sobrescribe el primer carácter del fichero poniendo el código hexadecimal 0xE5 que indica entrada de directorio libre).
2. Se borra el enlace al primer bloque del fichero. Con FAT no se borra y se puede ir a buscar. También a veces el fichero es tan pequeño que se encuentra en la propia tabla de ficheros como en el sistema NTFS que se guarda en la MFT (Master File Table). Estos ficheros se llaman "residentes".
3. Se declaran libres los bloques que el fichero ocupaba, en la tabla de bloques ocupados y libres, que es un bitmap normalmente.
4. Se borran los enlaces al resto de bloques asignados al fichero (dependiendo de cómo se gestiona el sistema de archivos).

Por lo tanto, **para recuperar los archivos hay que hacer el proceso inverso a lo que el sistema de ficheros ha hecho para borrarlos**. Es un proceso que depende del tipo del sistema de ficheros.

1. Buscar entradas de directorio que se han utilizado antes.
2. Leer la dirección del primer bloque del fichero.
3. Ir leyendo y guardando en un fichero nuevo el contenido de los bloques consecutivos mientras no estén asignados, asumiendo que los bloques se han asignado de forma consecutiva al fichero, que es lo normal en HDD (por ejemplo, asignados bloques 25,26,27,28,29).
4. Detenerse cuando se encuentra la marca de final de fichero (EOF) o bien cuando el siguiente bloque está asignado a otro fichero. En este último caso, puede pasar que:
 - el fichero podría estar **fragmentado** (se ha asignado un bloque no consecutivo)
 - bien se han **asignado sus bloques que se habían declarado libres a otro fichero** (y por tanto, se ha sobrescrito la información).

7 Proceso de búsqueda con Carving (cortar, esculpir)

Este proceso es utilizado principalmente en la informática forense para **extraer información a partir de una cantidad de datos en bruto sin necesidad de conocer el sistema de ficheros** con el que se han creado los ficheros.

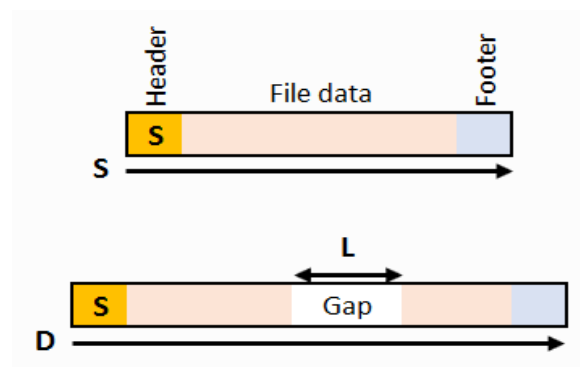
En general, todos los tipos de ficheros tienen características comunes, tienen una estructura similar. Por ejemplo, atendiendo a su estructura, todos los ficheros JPG/*JFIF empiezan por FF D8 FF E0 y terminan por FF D9.

MAGIC NUMBER: Los ficheros de un tipo, utilizan una constante conocida como Magic Number, la cual permite identificar el correspondiente tipo de fichero.
http://www.garykessler.net/library/file_sigs.html

Existen **diferentes técnicas de «file carving»:**

1. **Basadas en la cabecera de un fichero** y en el final o, si se desconoce éste, en el tamaño máximo de archivo (dato disponible en la cabecera).
2. **Basadas en la estructura de un fichero:** cabecera, pie, cadenas significativas, tamaño, etc.
3. **Basadas en el contenido del fichero:** miran la entropía (cantidad de información del fichero), reconocimiento del lenguaje (por ejemplo HTML), atributos estáticos (estructura fija del fichero), etc. Ejemplo: HTML, XML, etc.

Algunos ficheros también tienen marca de final de fichero, así como cabecera, o guardan el tamaño del fichero en la cabecera.



File Carving

De estos ficheros recuperados con Carving:

- **no podremos saber el nombre ni los metadatos** del sistema de archivos
- **tampoco el espacio de almacenamiento** real que ocupa

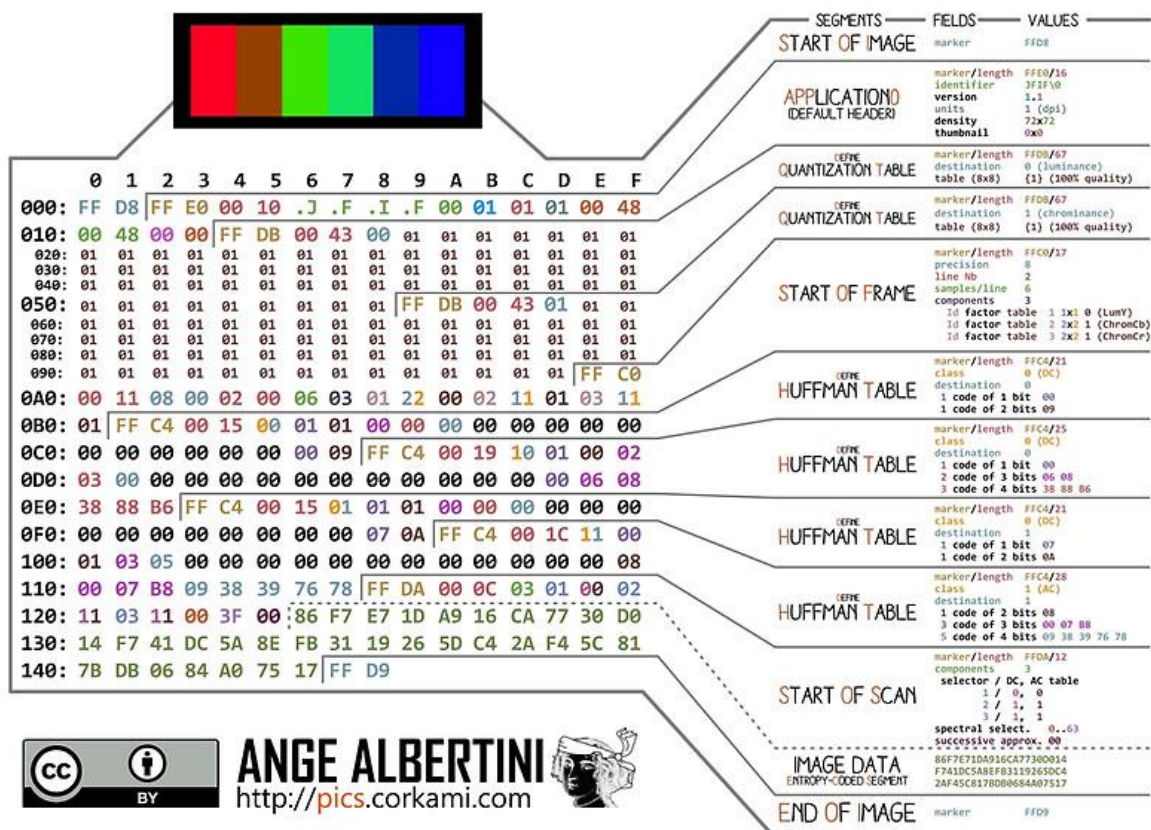
a no ser que parte de esta información se guarde en el mismo fichero como un metadato de su contenido.

Un ejemplo son los ficheros de fotos que contienen información EXIF.

<https://www.ionos.es/digitalguide/paginas-web/disenio-web/que-son-los-datos-exif/>

Esto implica que se debe conocer cuál es el formato de los diferentes tipos de archivos que se pueden guardar en el disco. Básicamente qué cabecera, contenido y cola tienen los archivos.

JPEG FILE INTERCHANGE FORMAT



JPEG IS THE ENCODING STANDARD, JFIF IS THE FILE FORMAT

Formato de fichero Jpeg

<https://www.disktuna.com/jpeg-recovery-lab-digital-photo-recovery/advanced-carving-for-digital-photos/>

Este método también permite extraer ficheros contenidos dentro de otros ficheros o simplemente concatenados detrás del fichero "contenedor".

Ejemplo, crear un jpg que contenga dentro dos imágenes, aunque sólo veamos una:

```
cat fitxer1.jpg fitxer2.jpg > fitxer3.jpg
```

Si visualizamos fitxer3.jpg, sólo veremos la imagen fitxer1.jpg. Así es que, cuidado, puede ser que dentro de un fichero se albergue también otro tipo de información.

7.1 Herramientas de Carving.

Enlaces interesantes:

- Ejemplo carving manual - <https://forensicallyfit.wordpress.com/2018/08/21/manual-file-carving/>
- Explicación y Ejemplos de carving - <https://www.infosecinstitute.com/resources/digital-forensics/file-carving/>

Lista de herramientas más utilizadas:

- Bulk Extractor - https://github.com/simsong/bulk_extractor
- Foremost - <https://foremost.sourceforge.net/>
- Scalpel - <https://github.com/sleuthkit/scalpel>
- Forensic Toolkit (FTK)
- AccessData
- Encase
- PhotoRec && TestDisk
- Revit
- Magic Rescue
- F-Engrave

8 Análisis de metadatos internos

Implica **examinar la información que se encuentra en las cabeceras o en el interior de** los archivos.

- Algunos ficheros contienen dentro del espacio asignado, algunos **metadatos**.
 - Por ejemplo, los **datos EXIF** de ficheros jpg
 - **metadatos de ficheros de Office o Microsoft 365**, que pueden contener el nombre del autor o fechas de modificación del archivo que contradicen los metadatos externos.
- **Herramientas:** Autopsy, Visores hexadecimales, por ej. <https://hexed.it/> (visor hexadecimal con detector de tipo de fichero) o detectores de firmas, por ej. <https://mark0.net/soft-trid-e.html> (TrID is an utility designed to identify file types from their binary.)

Referencias útiles:

- Analizar metadatos de ficheros Office - https://www.youtube.com/watch?v=siS53SeCwyY&list=PL3r_pj3xfqJWKSuCmW5l6W4n6BvJdn0DP&index=2
- Analizar metadatos de ficheros con imágenes JPG con EXIFtool - https://www.youtube.com/watch?v=HU_euJyxYB4&list=PL3r_pj3xfqJWKSuCmW5l6W4n6BvJdn0DP

9 Análisis de hashes

Implica **calcular el hash de los archivos y compararlos con los hash de archivos conocidos**. Esto permite:

- Descartar ficheros que se consideran "buenos" (como los de un sistema windows "net", o sea, sin malware).
- Buscar un fichero determinado por hash, sin tener en cuenta cambios de nombre ni extensión, por si alguien ha cambiado nombre y extensión para ocultarlo.
- Buscar ficheros que se consideran "malos", como una BD de pedofilia.
- Buscar archivos de malware conocidos.

Esto puede ayudar a descartar archivos del análisis (no analizamos los ficheros conocidos del sistema) o a identificar archivos sospechosos o maliciosos.

- **Herramientas:** Autopsy, Sleuth kit, comandos del Sistema operativo...
- Ejemplo para comprobar integridad (md5sum, pero existe sha256sum y genérico shasum):

```
//Enviar los valores del md5 de un fichero a un fichero de texto
$ md5sum practica.txt practica2.txt > check.md5
$ cat check.md5
b216ece280c40836e2090d74bb7963cd  practica.txt
b216ece280c40836e2090d74bb7963cd  practica2.txt

//comprobar todos los checksums
$ md5sum -c check.md5
practica.txt: CORRECTO
practica2.txt: CORRECTO
```

- Ejemplo Powershell, por defecto SHA256 (SHA1, SHA256, SHA384, SHA512, MD5):

```
Get-Filehash .\mi_archivo.txt -Algorithm MD5 | Format-List
Get-Filehash .\mi_archivo.txt -Algorithm SHA1 | Format-List
```

<https://learn.microsoft.com/es-es/powershell/module/microsoft.powershell.utility/get-filehash?view=powershell-7.4#examples>

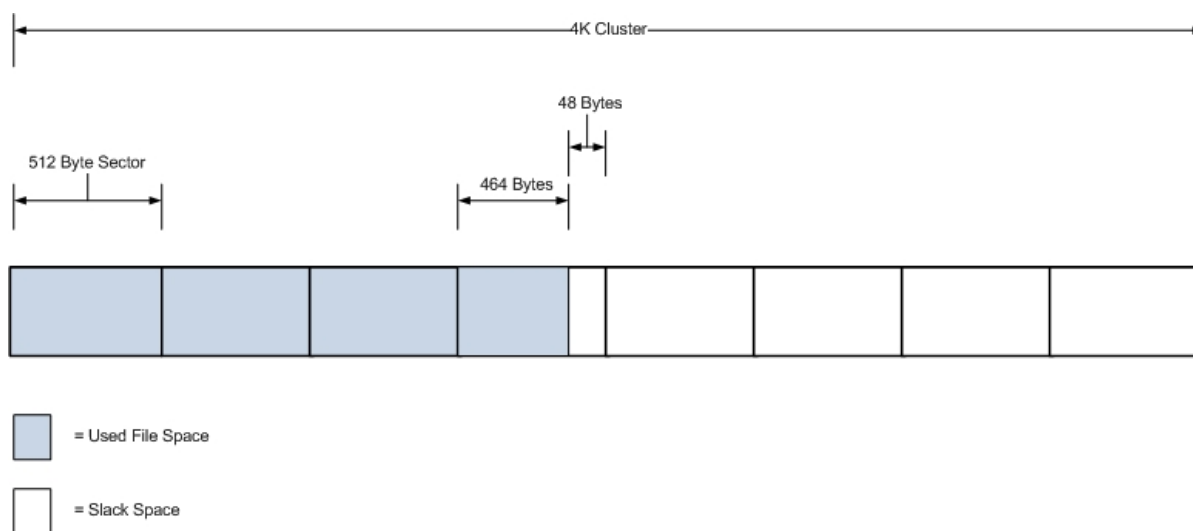
10 Buscar información oculta en el disco

Los sistemas de archivos trabajan con una unidad mínima de almacenamiento llamada **"bloque"** en Linux y **"clúster"** o **"unidad de asignación"** en Windows.

- Esta unidad mínima de asignación corresponde a una agrupación de sectores.
- Los sectores se gestionan y se acceden en grupos por motivos de eficiencia.

Cuando un archivo pide espacio, **se le asigna como mínimo una unidad de asignación completa.**

- Todos los archivos **desaprovechan una parte de la última unidad de asignación.**
- **El trozo que no se utiliza puede contener una porción de datos guardados por un fichero anterior que fue borrado** y sus bloques liberados por uso posterior.
- **Estos datos podrían ser una prueba** para un caso.



Slack space de un clúster

También puede quedar espacio sobrante entre las particiones (por ejemplo, crear 3 particiones y borrar la del medio), o en zonas no accesibles del disco y otras.

11 Análisis de los artefactos del Sistema Operativo

En el espacio asignado tenemos todos los **ficheros de datos y del sistema operativo**. Estos ficheros del sistema operativo configuran los llamados **"Artefactos"**.

- Los **artefactos de Windows son los objetos que contienen información sobre las actividades que realiza el sistema y los usuarios de Windows.**
 - El tipo de información y la ubicación del artefacto varía de un sistema operativo a otro.
 - Los artefactos de Windows contienen información sensible que se recoge y analiza en el momento del análisis forense.

Hay que localizarlos físicamente en:

- discos del sistema
- memoria, donde también encontramos copias de los artefactos (copias temporales de trabajo, normalmente).

En Windows existen un montón de artefactos que nos permiten investigar:

- Perfiles de usuario (User Profiles).
- Registro de Windows (Windows Registry).
- Cuentas de usuarios y su uso.
- Información sobre archivos.
- Información sobre ejecución de programas.
- Información sobre dispositivos USB conectados.

Estos artefactos tienen formas diferentes según la versión del sistema Windows.

11.1 El registro de Windows.

Contiene información sobre la configuración del sistema y de los usuarios. También están los registros de eventos de Windows (logs) o el registro de syslog en Linux, que sirven para identificar eventos o actividades sospechosas o maliciosas.

Herramientas útiles: Registry viewer, Registry Explorer, <https://www.tecmint.com/best-linux-log-monitoring-and-management-tools/>

12 Otras fuentes de evidencias

Aparte de los medios y dispositivos tradicionales, también existen otras fuentes, de las cuales también es posible obtener evidencias.

12.1 Análisis de red.

Implica examinar la actividad de la red para **identificar conexiones o comunicaciones sospechosas**.

Herramientas: Wireshark, tshark, tcpdump... para capturar y analizar el tráfico de red.

12.2 Análisis de memoria

Implica examinar la memoria del sistema para **identificar procesos o actividades sospechosas que pueden no estar registrados** en los archivos de registro del sistema. En memoria existen copias temporales de los artefactos que se guardan a disco mencionados anteriormente.

Herramientas: como Volatility Framework o memProcFS.

12.3 Análisis de archivos de intercambio (swap)

El archivo de intercambio es un área de almacenamiento temporal utilizada por el sistema operativo cuando la memoria RAM del sistema está llena. Contiene la información de páginas de memoria RAM desalojadas.

El análisis implica **examinar el archivo de intercambio para identificar procesos o actividades sospechosas** que pueden no estar registrados en los archivos de registro del sistema.

Herramientas: Swap Digger - https://github.com/sevagas/swap_digger , EnCase, FTK, Axiom, Autopsy

12.4 Análisis de esteganografía

La esteganografía es el arte de **ocultar información dentro de archivos multimedia**, como imágenes o audio. El análisis implica examinar archivos multimedia para identificar información oculta.

Herramientas: Steghide u OutGuess.

12.5 Análisis de firmas de malware

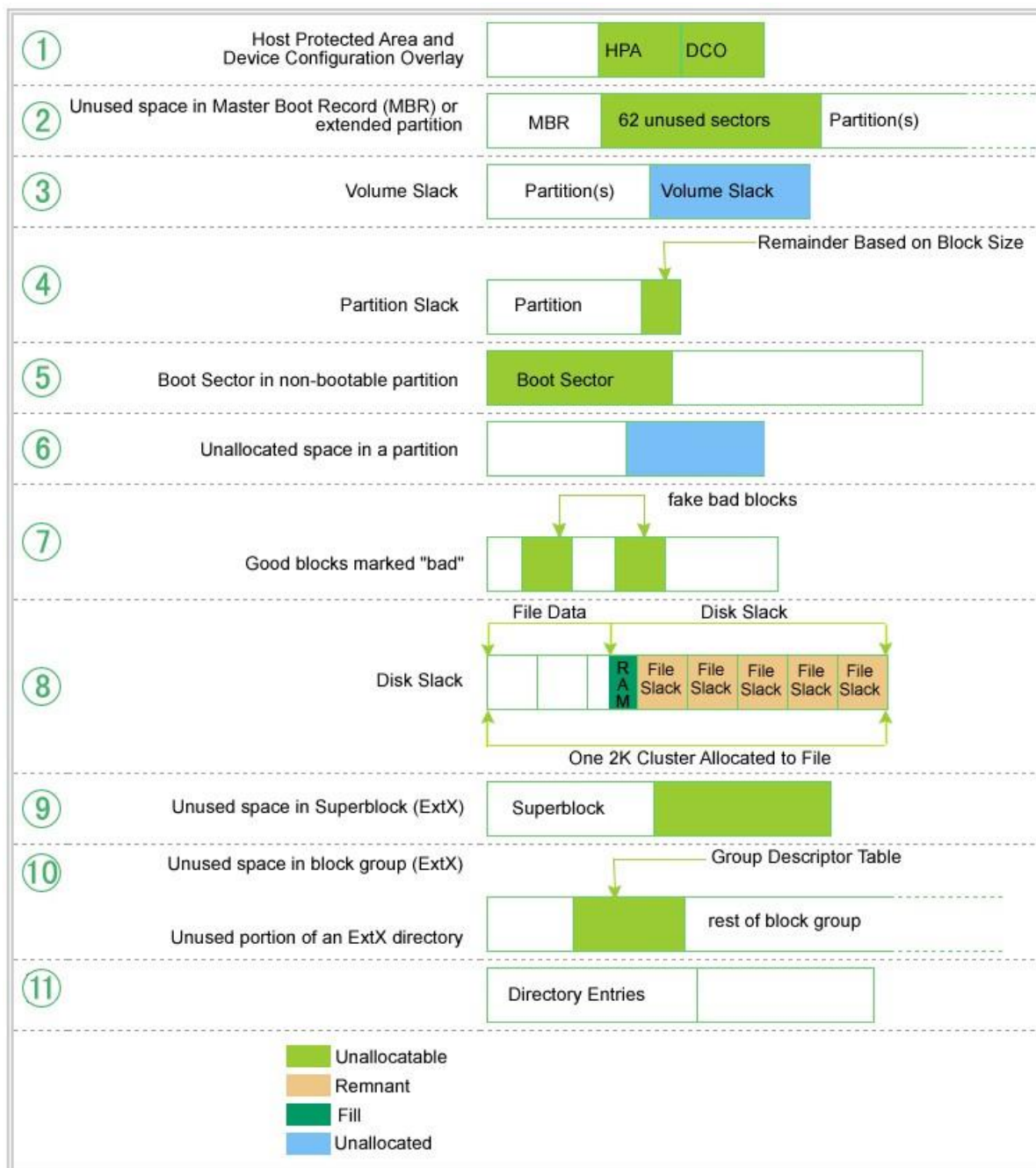
El archivo Existen bases de datos que contienen los indicios (ficheros modificados, código inyectado, direcciones IP de control remoto, etc.) que se ha descubierto que permiten encontrar malware o actividad maliciosa en el sistema (Indicadores de compromiso o IoC)

Implica **identificar patrones o firmas en los archivos** para identificar archivos maliciosos conocidos o sospechosos.

Herramientas: ClamAV o Yara para buscar firmas en los archivos.

13 Otras formas de esconder información en los discos

Hay otras formas de esconder información, utilizando métodos avanzados, que se pueden observar en el siguiente diagrama:



Esconder información en el disco

http://www.berghel.net/publications/data_hiding/data_hiding.php

14 Referencias

- 2025 - Soft carving y artículos sobre recuperación de particiones, archivos de vídeo y etc. - CNW recovery - [Forensic, Video and Data recovery software from CnW](#)
- Fragview's main purpose is to visualize disk content by displaying its map. - [GitHub - i-rinat/fragview: disk fragmentation visualizer based on FIEMAP and FIBMAP ioctls \(linux specific\)](#)
- Klennet Carver y explicación carving - [Complex carving overview](#)
- 2006 - Esconder información en el disco
 - [Data Hiding Tactics for Windows and Unix File Systems](#)
 - http://www.berghel.net/publications/data_hiding/AiC_data%20hiding.pdf